

Security Bug Report: CORS Misconfiguration

Victor.g.
me@gmail.com

June 11, 2025

Overview

Issue: severe CORS misconfiguration- api leaks info regardless of the origin header-with or without an origin=Wildcard origin + credentials.

Severity: High

Tested on: Anonymized (<https://itworkledonmyend.com>)

Date of Discovery: June 11th, 2025

Vulnerability Description

```
# Access-Control-Allow-Origin: *  
#Access-Control-Allow-Credentials: true
```

It's not just a CORS issue—it's also likely caused by: -An open, unauthenticated API (bad access control),

- the endpoint responds with JSON to anyone (no session/token validation),
- permissive CORS headers, making exploitation trivial.

Steps to Reproduce

1. Ensure you are logged into <https://vulnerable-app.com> in your browser.
2. Open a malicious site under the attacker's control (e.g., <https://attacker.com>).
3. The attacker's site sends a cross-origin 'fetch()' request:

```
fetch('https://itworkledonmyend.com/api/c#####', {  
  credentials: 'include'  
})  
.then(res => res.json())  
.then(data => console.log(data));
```

4. The response from the target includes credentials and sensitive JSON data.

Expected vs Actual Behavior

Expected: The server should deny cross-origin requests or restrict them to specific trusted origins.

Actual: The server responds with full data to any origin, including attacker-controlled domains.

Impact

- Sensitive user data leakage - Possible account takeover through session hijacking - Violates CORS specification by combining wildcard origin and credentials

Recommendations

- Do not use 'Access-Control-Allow-Origin: *' when 'Access-Control-Allow-Credentials: true' is set.
- Define a whitelist of trusted origins and validate them server-side.
- Use CORS middleware/libraries with secure default settings.

Proof of Concept

A working HTML/JS PoC file is included in the link <https://imgur.com/a/FDCLDDr>.

Disclaimer

This proof-of-concept is created solely for educational and research purposes by an independent security researcher. No unauthorized access, disruption, or harm was caused to any systems or data. All testing was performed in controlled environments or with explicit permission from the system owners. This report aims to help improve security by responsibly disclosing potential vulnerabilities. Please do not misuse this information